

Wapiti vulnerability report

Target: <https://doc.gold.ac.uk/usr/278/>

Date of the scan: Wed, 10 Dec 2025 03:00:20 +0000. Scope of the scan: folder. Crawled pages: 20

Summary

Category	Number of vulnerabilities found
Backup file	0
Cleartext Submission of Password	0
Weak credentials	0
CRLF Injection	0
Content Security Policy Configuration	1
Cross Site Request Forgery	0
Potentially dangerous file	0
Command execution	0
Path Traversal	0
Fingerprint web application framework	0
Fingerprint web server	0
Htaccess Bypass	0
HTML Injection	0
Clickjacking Protection	1
HTTP Strict Transport Security (HSTS)	1

Category	Number of vulnerabilities found
MIME Type Confusion	1
HttpOnly Flag cookie	0
Unencrypted Channels	0
Inconsistent Redirection	1
Information Disclosure - Full Path	11
LDAP Injection	0
Log4Shell	0
NS takeover	0
Open Redirect	0
Reflected Cross Site Scripting	0
Secure Flag cookie	0
Spring4Shell	0
SQL Injection	0
TLS/SSL misconfigurations	0
Server Side Request Forgery	0
Stored HTML Injection	0
Stored Cross Site Scripting	0
Subdomain takeover	0
Blind SQL Injection	0
Unrestricted File Upload	0
Vulnerable software	0

Category	Number of vulnerabilities found
Internal Server Error	9
Resource consumption	0
Review Webserver Metafiles for Information Leakage	0
Fingerprint web technology	0
HTTP Methods	0
TLS/SSL misconfigurations	0

Content Security Policy Configuration

Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

 Vulnerability found in /usr/278/

Description	HTTP Request	cURL command line	WSTG Code
CSP is not set for URL: https://doc.gold.ac.uk/usr/278/			

Solutions

Configuring Content Security Policy involves adding the Content-Security-Policy HTTP header to a web page and giving it values to control what resources the user agent is allowed to load for that page.

References

- [Mozilla: Content Security Policy \(CSP\)](#)
- [OWASP: Content Security Policy Cheat Sheet](#)
- [OWASP: How to do Content Security Policy \(PDF\)](#)
- [OWASP: Content Security Policy](#)

Clickjacking Protection

Description

Clickjacking is a technique that tricks a user into clicking something different from what the user perceives, potentially revealing confidential information or taking control of their computer.

● Vulnerability found in /usr/278/

Description	HTTP Request	cURL command line	WSTG Code
X-Frame-Options is not set			

Solutions

Implement X-Frame-Options or Content Security Policy (CSP) frame-ancestors directive.

References

- [OWASP: Clickjacking](#)
- [KeyCDN: Preventing Clickjacking](#)

HTTP Strict Transport Security (HSTS)

Description

HSTS is a web security policy mechanism that helps to protect websites against man-in-the-middle attacks such as protocol downgrade attacks and cookie hijacking.

● Vulnerability found in /usr/278/

Description	HTTP Request	cURL command line	WSTG Code
Strict-Transport-Security is not set			

Solutions

Implement the HTTP Strict Transport Security header to enforce secure connections to the server.

References

- [OWASP: HTTP Strict Transport Security](#)
- [KeyCDN: Enabling HSTS](#)

MIME Type Confusion

Description

MIME type confusion can occur when a browser interprets files as a different type than intended, which could lead to security vulnerabilities like cross-site scripting (XSS).

● **Vulnerability found in /usr/278/**

Description	HTTP Request	cURL command line	WSTG Code
X-Content-Type-Options is not set			

Solutions

Implement X-Content-Type-Options to prevent MIME type sniffing.

References

- [OWASP: MIME Sniffing](#)
- [KeyCDN: Preventing MIME Type Sniffing](#)

Inconsistent Redirection

Description

An HTTP 3xx redirection response should typically contain only minimal content (or none), as

clients are expected to follow the Location header. However, this response also contains HTML content (such as links or forms). This may confuse clients, expose unintended information, or allow attackers to craft malicious redirections.

● **Vulnerability found in /usr/278/users/audit**

Description	HTTP Request	cURL command line	WSTG Code
3xx redirection contains unexpected HTML body (links/forms)			

Solutions

Ensure that 3xx HTTP responses only return the appropriate redirection headers and do not include unnecessary HTML content. If user feedback is required, provide a clear message without interactive elements (like links or forms). Always rely on the Location header for redirection logic.

References

- [ZAP Alert 10044-1: Inconsistent Redirection](#)
- [MDN: HTTP Redirections](#)
- [WSTG: Review Webpage Content for Information Leakage](#)

Information Disclosure - Full Path

Description

The application response discloses full system paths. This information can help attackers understand the server environment, directory structure, and operating system, which can facilitate further attacks.

● **Vulnerability found in /usr/278/**

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /usr/278/main.css			

● Vulnerability found in /usr/278/

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /usr/278/weather			

● Vulnerability found in /usr/278/books/search

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /usr/278/books/search-result			

● Vulnerability found in /usr/278/users/login

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /usr/278/users/loggedin			

● Vulnerability found in /usr/278/users/registered

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /users/registered			

● Vulnerability found in /usr/278/users/loggedin

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /users/loggedin			

● Vulnerability found in /usr/278/weather

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /usr/278/weather.css			

● Vulnerability found in /usr/278/books/bookadded

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /home/axavi001/berties-books/node_modules/mysql2/lib/packets/packet.js			

● Vulnerability found in /usr/278/books/bookadded

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /home/axavi001/berties-books/node_modules/mysql2/lib/commands/command.js			

● Vulnerability found in /usr/278/books/bookadded

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /home/axavi001/berties-books/node_modules/mysql2/lib/base/connection.js			

● Vulnerability found in /usr/278/books/bookadded

Description	HTTP Request	cURL command line	WSTG Code
Response contains potential system path: /home/axavi001/berties-books/node_modules/mysql2/lib/packet_parser.js			

Solutions

Ensure that error messages and application responses do not disclose full filesystem paths or other sensitive system information. Use generic error messages for end users and log detailed errors only on the server side.

References

- [OWASP: Information Leakage](#)
- [CWE-209: Generation of Error Message Containing Sensitive Information](#)
- [WASC-13: Information Leakage](#)

Internal Server Error

Description

An error occurred on the server's side, preventing it to process the request. It may be the sign of a vulnerability.

● **Anomaly found in /usr/278/books/bookadded**

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter name			

● **Anomaly found in /usr/278/users/registered**

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter first			

● **Anomaly found in /usr/278/weather**

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter city			

● **Anomaly found in /usr/278/books/bookadded**

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter name			

● Anomaly found in `/usr/278/weather`

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter city			

● Anomaly found in `/usr/278/users/registered`

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter first			

● Anomaly found in `/usr/278/books/bookadded`

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter name			

● Anomaly found in `/usr/278/users/registered`

Description	HTTP Request	cURL command line	WSTG Code
The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter username			

● Anomaly found in /usr/278/books/bookadded

Description

HTTP Request

cURL command line

WSTG Code

The server responded with a 500 HTTP error code while attempting to inject a payload in the parameter price

Solutions

More information about the error should be found in the server logs.

References

- [Wikipedia: List of 5xx HTTP status codes](#)
- [OWASP: Improper Error Handling](#)